UNIT 4 · TOPIC 4.3

Endpoint Hardening Controls

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. A company wants to reduce device security risk across all departments. Which of the following is best classified as a managerial control for device security?

- ○ A. Configuring antivirus software on all employee laptops
- **● B. Developing an acceptable use policy for company-owned devices**
- ○ C. Enabling automatic screen-lock timeouts on workstations
- ○ D. Installing host-based firewalls on all workstations

Correct answer: B

Why: Managerial (administrative) controls are governance and policy measures, things like acceptable use policies, security plans, and risk assessments. Configuring antivirus (A), enforcing screen-lock timeouts (C), and installing firewalls (D) are all technical controls applied directly to devices.

*Why the others are wrong: **A**, Antivirus configuration is a technical control, not a managerial one, it is implemented in software, not policy. **C**, Screen-lock timeouts are enforced through OS or group policy settings, a technical/operational control, not a managerial directive. **D**, Host-based firewalls are a classic technical control applied at the device level.*

2. Which statement best describes how anti-malware software helps protect a device?

- ○ A. It encrypts all files on the device so malware cannot read them
- ○ B. It blocks unauthorized network connections at the network perimeter
- **● C. It detects and removes malicious programs before or after they execute**
- ○ D. It prevents users from installing unapproved software through group policy enforcement

Correct answer: C

Why: Anti-malware software scans for, detects, and removes or quarantines malicious programs, before execution (on-access scanning) or after (on-demand scanning). It operates at the endpoint level on individual files and processes.

*Why the others are wrong: **A**, Encrypting files is the function of full-disk encryption or file encryption tools, not anti-malware software. **B**, Blocking unauthorized network connections at the perimeter is the function of a network or host-based firewall, not anti-malware. **D**, Restricting software installation via group policy is an application whitelisting or endpoint management control, not anti-malware.*

3. What is the primary security reason an organization should apply operating system updates promptly?

- ○ A. Updates add new features that improve user productivity
- **● B. Updates patch known vulnerabilities that adversaries could actively exploit**
- ○ C. Updates reduce the device's overall power consumption
- ○ D. Updates ensure compatibility with the latest peripheral hardware

Correct answer: B

Why: OS updates frequently include security patches that close known vulnerabilities. Once a CVE is published, adversaries can exploit unpatched systems. Promptly applying updates reduces the window of exposure to those known vulnerabilities.

*Why the others are wrong: **A**, New features are a benefit of updates but are not the security rationale for promptness. **C**, Power consumption is unrelated to the security value of OS updates. **D**, Hardware compatibility is a functional, not a security, concern.*

4. An agricultural-tech company's GPS-guided tractors are running firmware that is 18 months behind the current vendor release. A CVE with a CVSS score of 8.7 has just been published for the outdated firmware version. Which risk-management strategy has the greatest immediate impact on reducing device risk?

- ○ A. Disconnecting all tractors from the internet until a full risk assessment is completed

● **B. Applying the available firmware update to address the published CVE**

○ C. Deploying network-based intrusion detection sensors on the tractor control network

○ D. Requiring equipment operators to sign an acceptable use policy before accessing the machinery

Correct answer: B

Why: Patching directly closes the known vulnerability identified by the CVE, eliminating the root cause of the risk. The CVE is published and the vendor patch is available, making remediation the highest-impact immediate action. Disconnecting (A) is a compensating control that does not fix the vulnerability. IDS (C) detects but does not prevent exploitation. An AUP (D) is a managerial control that has no technical effect on a firmware vulnerability.

*Why the others are wrong: **A**, Disconnecting reduces exposure temporarily but leaves the underlying vulnerability in place and disrupts operations, appropriate only if the patch cannot be applied immediately. **C**, IDS is a detection control; it can alert on exploitation attempts but does not prevent them or close the vulnerability. **D**, Acceptable use policies govern user behavior and have no impact on a firmware-level technical vulnerability.*

5. A company is comparing two endpoint protection strategies: Strategy 1 uses signature-based antivirus updated weekly; Strategy 2 uses behavior-based anti-malware updated daily. Which explanation best accounts for Strategy 2 providing stronger protection against novel malware?

○ A. Behavior-based tools are less resource-intensive, so they scan more files per second

○ B. Daily definition updates guarantee the signature database is always complete and current

● **C. Signature-based tools can only detect threats already in their definition database, whereas behavior-based tools flag suspicious activity patterns regardless of whether the malware has a known signature**

○ D. Behavior-based tools encrypt endpoint files before malware can access them

Correct answer: C

Why: Signature-based detection matches files against a database of known malware signatures, so novel malware with no existing signature evades it. Behavior-based (heuristic) detection monitors program behavior (e.g., attempts to modify system files, privilege escalation, unusual network calls) and can flag unknown malware based on suspicious patterns.

*Why the others are wrong: **A**, Behavior-based analysis is typically more resource-intensive than signature lookups, this reverses reality. **B**, More frequent updates help with signature-based tools but do not address the fundamental gap: novel malware has no signature yet, regardless of update frequency. **D**, Behavior-based anti-malware does not encrypt files; that is a function of data-protection tools like full-disk encryption.*

6. An audit reveals that employees are connecting personal USB drives to company laptops, creating a potential malware introduction vector. Which combination of controls most effectively addresses this risk by pairing a managerial control with a technical control?

○ A. Installing antivirus software and enabling automatic scans on USB insertion

○ B. Enabling a host-based firewall and logging all USB connection events

○ C. Applying the latest OS patches and delivering phishing awareness training

● **D. Creating a removable media policy and configuring device control software to block unauthorized USB devices**

Correct answer: D

Why: A removable media policy is a managerial control (governance), while device control software that blocks unauthorized USB drives is a technical control that enforces it. Together they address both the policy and enforcement dimensions of the risk. Option A uses two technical controls. Option C addresses different threats (vulnerabilities and phishing). Option B uses a technical control (firewall) that does not address USB-based malware introduction, plus a logging measure.

*Why the others are wrong: **A**, Both antivirus and automated scanning are technical controls, no managerial control is included in this pairing. **B**, A host-based firewall controls network traffic, not USB/physical media access; this combination does not directly mitigate the identified risk. **C**, Patching and phishing training address vulnerability exploitation and social engineering, not the USB removable media threat.*

7. An organization deploys behavior-based anti-malware, enforces a quarterly patch-management policy, and mandates annual security awareness training. A threat actor successfully exploits a zero-day vulnerability in a productivity application before any patch is available. Which statement best evaluates the effectiveness of the organization's risk-management strategy?

○ A. The strategy is ineffective because none of the controls prevented the zero-day attack

● B. The strategy is partially effective; the controls reduce exposure to known threats and residual risk from human error, but zero-day exploitation inherently falls outside the protection scope of patch management and may evade behavior-based detection if the exploit is sufficiently novel

○ C. The organization should have implemented a stricter acceptable use policy to prevent zero-day exploitation

○ D. The anti-malware software must have been misconfigured, since properly deployed behavior-based tools reliably detect zero-day exploits

Correct answer: B

Why: A layered risk-management strategy reduces, but cannot eliminate, risk. Patch management cannot address a zero-day by definition (no patch exists yet). Behavior-based anti-malware may detect anomalous behavior associated with the exploit, but sophisticated zero-days are specifically engineered to evade heuristic detection. The controls remain valuable for the threat landscape they do address. A correct evaluation acknowledges both the controls' value and their limits against zero-day threats, consistent with NIST SP 800-30 residual risk concepts.

*Why the others are wrong: **A**, Declaring the entire strategy ineffective ignores the protection it provides against known vulnerabilities, phishing, and other threat categories, a zero-day is one specific scenario the controls cannot address by nature. **C**, An acceptable use policy governs user behavior; it has no technical mechanism to prevent software-level zero-day exploitation. **D**, Behavior-based anti-malware increases detection probability for novel threats but is not a guaranteed control against zero-days, this overstates its capability.*

8. A risk manager must choose an update policy for internet-connected farm equipment: Policy 1 applies firmware updates automatically upon vendor release; Policy 2 stages updates through a test environment before production deployment. Which analysis most accurately evaluates the security trade-off between these policies?

○ A. Both policies carry equivalent risk because firmware updates rarely introduce new vulnerabilities or stability issues

○ B. Policy 1 is always preferable because minimizing the vulnerability exposure window is the only security consideration

○ C. Policy 2 eliminates vulnerability risk because testing ensures updates contain no exploitable flaws

● D. Policy 1 minimizes the vulnerability window but risks deploying untested changes that could disrupt critical equipment operation; Policy 2 reduces that operational risk but extends the period of known vulnerability exposure, the correct choice depends on the severity of the CVE and the criticality of uninterrupted equipment operation

Correct answer: D

Why: This is a classic security-versus-availability trade-off. Policy 1 minimizes the time between patch release and deployment (reducing vulnerability exposure) but skips validation, which for safety-critical machinery (GPS-guided autonomous equipment) could cause operational failure, itself a security and safety risk. Policy 2 is safer operationally but extends exposure to known CVEs. NIST SP 800-40 (patch management guidance) recommends risk-based prioritization: for critical CVEs, the exposure risk may outweigh staging delay; for lower-severity patches, staging is preferable. The optimal decision is context-dependent.

*Why the others are wrong: **A**, Firmware updates for complex embedded systems do introduce instability risks, and the vulnerability window is a real, measurable security exposure, the policies are not equivalent. **B**, This ignores the operational risk of deploying untested firmware to autonomous machinery, which could cause physical harm or production loss, availability and integrity are also security properties. **C**, Testing reduces the probability of update-induced failure but cannot guarantee the absence of flaws; testing also does not close the vulnerability window during the staging period.*

9. Following reports of cyberattacks against internet-connected agricultural equipment, a security engineer must recommend a prioritized risk-management strategy. The equipment currently runs outdated firmware, lacks anti-

malware capability, and has no host-based firewall configured. Referencing the NIST SP 800-53 control framework, which sequence of controls best addresses the highest-risk gaps first?

- **● A. Conduct a risk assessment and establish a patch-management policy first; then apply firmware updates to remediate known CVEs; then implement host-based firewalls and anti-malware as layered technical controls**
- ○ B. Configure host-based firewalls on all devices first, then install anti-malware, then apply firmware updates
- ○ C. Install behavior-based anti-malware on all devices first, as endpoint malware detection is the highest-priority control for IoT equipment
- ○ D. Deliver security awareness training and establish an acceptable use policy before implementing any technical controls, to ensure operator compliance

Correct answer: A

Why: NIST SP 800-53 and the broader RMF (Risk Management Framework) call for risk assessment before control selection to ensure controls address actual risk priorities. With outdated firmware and published CVEs, patching is the highest-urgency technical control because it closes known, actively exploitable vulnerabilities. Firewalls and anti-malware then provide defense-in-depth. Starting with firewalls alone (B) leaves known firmware vulnerabilities unaddressed. Starting with anti-malware alone (C) prioritizes detection over closing the known vulnerability gap. Starting with training only (D) provides no immediate technical risk reduction for hardware-level vulnerabilities.

*Why the others are wrong: **B**, Installing firewalls without first patching known firmware CVEs leaves the root vulnerability open, an adversary who gains access through the unpatched firmware bypasses the firewall entirely from within. **C**, Anti-malware is valuable but does not address the fundamental risk of running firmware with known, published vulnerabilities that can be exploited without malware delivery. **D**, Managerial controls like training and AUPs govern human behavior; they have no technical effect on hardware-level firmware vulnerabilities in autonomous equipment.*

10. A technician is setting up a host-based firewall on a Windows workstation for the first time. Which action represents the correct first step?

- **● A. Access the firewall configuration through the operating system's built-in security settings**
- ○ B. Download and install a third-party antivirus application
- ○ C. Update the device's network adapter driver to the latest version
- ○ D. Create a new administrator account dedicated to firewall management

Correct answer: A

Why: Configuring a host-based firewall begins by accessing the firewall settings through the OS, on Windows, this is Windows Defender Firewall in the Control Panel or Settings. From there the technician can enable the firewall and add or modify rules. The other options address separate tasks unrelated to firewall setup.

*Why the others are wrong: **B**, Installing antivirus is a separate security task; it does not configure a host-based firewall. **C**, Updating a network driver may be needed for connectivity troubleshooting but is not a step in firewall configuration. **D**, A dedicated admin account is not required to configure the built-in firewall and is not the first step in the process.*

11. A technician has just finished installing anti-malware software on a newly imaged workstation. Which step is most important to perform immediately afterward?

- ○ A. Restart the workstation to refresh network adapter settings
- ○ B. Add the anti-malware installation directory to the host-based firewall's outbound allow list
- ○ C. Configure the software to perform a full scan once per week and disable real-time protection to save resources
- **● D. Update the anti-malware software's virus definition database before running the first scan**

Correct answer: D

Why: A freshly installed anti-malware application ships with definitions that may already be hours or days old. Updating definitions before scanning ensures the tool can detect current known threats. Running a scan with outdated definitions leaves the device vulnerable to recently discovered malware.

*Why the others are wrong: **A**, Restarting may be required after some installations but is not the most important security action for effective anti-malware protection. **B**, The anti-malware installation directory does not need a firewall exception; this is not a standard or*

necessary configuration step. ***C****, Scheduling only weekly scans and disabling real-time protection significantly weakens endpoint security, real-time protection is a critical component of anti-malware effectiveness.*

12. A device administrator discovers that automatic operating system updates have been disabled on a company laptop. Which action should the administrator take first to implement the correct mitigation?

○ A. Uninstall all recently added third-party applications

○ B. Run a full antivirus scan to check for existing malware before making any changes

● C. Re-enable automatic updates in the operating system settings

○ D. Reset the device to factory settings to remove any unauthorized configuration changes

Correct answer: C

Why: The identified misconfiguration is that automatic updates are disabled. The direct remediation is to re-enable automatic updates, this restores the control that ensures security patches are applied promptly. The other actions, while sometimes appropriate in other scenarios, do not directly address the specific misconfiguration identified.

Why the others are wrong: ***A****, Uninstalling third-party applications is unrelated to the update configuration and could remove legitimate software.* ***B****, Running an antivirus scan is a separate security action; the specific issue identified is the disabled update setting, which should be fixed directly.* ***D****, A factory reset is a disproportionate response to a single misconfiguration and would result in significant data and configuration loss.*

13. A network administrator needs to configure a host-based firewall on an employee's laptop to allow outbound HTTPS traffic while blocking all unsolicited inbound connections. Which firewall rule set correctly implements this policy?

○ A. Block all inbound traffic; allow all outbound traffic on all ports

○ B. Allow inbound TCP port 443; block all other inbound; allow outbound TCP port 443; block all other outbound

○ C. Allow all inbound traffic on port 443; block all other ports bidirectionally

● D. Block all unsolicited inbound connections; allow outbound TCP port 443; block all other outbound traffic

Correct answer: D

Why: The policy requires: (1) block all unsolicited inbound connections, no allow rule for inbound is needed since the policy does not require accepting any inbound traffic; (2) allow outbound on TCP port 443 (HTTPS); (3) block all other outbound. Option A allows all ports outbound, too permissive. Option B allows inbound on port 443, which contradicts the requirement to block unsolicited inbound. Option C allows all inbound on port 443, directly violating the requirement.

Why the others are wrong: ***A****, Allowing all outbound traffic on all ports is overly permissive, the policy specifies only HTTPS (port 443) outbound.* ***B****, This rule allows inbound TCP 443, which permits unsolicited inbound HTTPS connections, this contradicts the stated policy.* ***C****, Allowing all inbound traffic on port 443 opens the device to unsolicited inbound connections, violating the core requirement.*

14. A security team confirms that a critical vulnerability (CVSS 9.1) affects the OS on all company endpoints. The vendor patch is available. Which implementation sequence best follows industry patch-management best practice?

○ A. Deploy the patch to all production systems immediately to minimize exposure time

○ B. Wait 30 days to observe community feedback on the patch's stability before deploying to any system

● C. Test the patch in a staging environment, document the test results, then deploy to production in prioritized order starting with the highest-risk systems

○ D. Apply the patch only to systems that handle sensitive data and monitor all other systems for signs of exploitation

Correct answer: C

Why: Best practice for patch management (per NIST SP 800-40) calls for testing patches in a non-production environment before broad deployment to catch compatibility issues, documenting findings, then rolling out to production in a risk-prioritized order. For a critical CVE (9.1), the staging period should be brief, but skipping it entirely risks production outages if the patch causes unexpected failures.

*Why the others are wrong: **A**, Deploying immediately to all production systems without testing risks introducing patch-induced outages, especially critical for systems running continuous processes. **B**, A 30-day hold is not risk-proportionate for a CVSS 9.1 vulnerability, the exposure window is too long for a critical severity rating. **D**, Leaving non-sensitive systems unpatched creates lateral movement opportunities; adversaries often compromise lower-security endpoints as a stepping stone to sensitive systems.*

15. An audit at an agricultural-tech company reveals that employees are using personal smartphones to access work email on the corporate network without any Mobile Device Management (MDM) enrollment. Which implementation step should a security engineer take first to mitigate this risk?

○ A. Block all smartphone MAC addresses at the perimeter firewall

● B. Deploy an MDM solution and establish a BYOD policy requiring device enrollment before network access is permitted

○ C. Configure the email server to reject login requests from mobile device user agents

○ D. Issue company-owned smartphones to all employees to replace personal devices

Correct answer: B

Why: MDM enrollment gives the organization visibility and control over devices accessing corporate resources (enforcing encryption, remote wipe, compliance checks), while a BYOD policy provides the governance framework that justifies and defines the requirement. This pairs a technical control with a managerial control. MAC filtering (A) is trivially bypassed via MAC spoofing. Blocking mobile user agents (C) prevents all mobile email access, including legitimate use. Issuing company devices (D) is expensive, slow to implement, and doesn't address the immediate risk.

*Why the others are wrong: **A**, MAC addresses can be spoofed in minutes, this control is easily circumvented and provides a false sense of security. **C**, Blocking all mobile user agents removes a legitimate business capability entirely rather than managing it securely. **D**, Device replacement is a long-term procurement decision and does not address the immediate unmanaged-device risk on the network.*

16. A security engineer at an agricultural-tech company has configured host-based firewalls on all internet-connected tractors, blocking all inbound connections and restricting outbound traffic to the vendor's update servers and the company control platform only. Two weeks after deployment, one tractor loses connectivity to the GPS navigation service. Which action best reflects correct mitigation implementation and change-logging practice aligned with NIST CM and AU control families?

○ A. Revert all firewall rules to their pre-implementation defaults to restore connectivity and document the reversion

○ B. Disable the host-based firewall on the affected tractor and continue monitoring for further incidents

● C. Review the firewall rule logs to confirm the GPS service traffic is being blocked; add a specific allow rule for the GPS service's destination IP range and port; document the rule change with the business justification; and update the security baseline accordingly

○ D. Issue a standing policy waiver exempting all GPS-connected tractors from the firewall policy and record the waiver approval in the risk register

Correct answer: C

Why: The correct approach follows NIST CM-3 (Configuration Change Control) and AU-2 (Event Logging): investigate the firewall logs to confirm the root cause (blocked GPS traffic), make the minimum necessary change (a targeted allow rule for the specific service), document the change with business justification, and update the baseline. This preserves the security control while restoring the business function. Reverting all rules (A) eliminates the protection entirely. Disabling the firewall (B) violates least-privilege and leaves the device unprotected. A blanket waiver (D) is a policy exception that should be a last resort, not the first response to a targeted connectivity issue.

*Why the others are wrong: **A**, Reverting all firewall rules removes the entire control to fix a single service gap, disproportionate and leaves all other inbound/outbound restrictions removed. **B**, Disabling the firewall entirely violates the principle of least privilege and removes protection for all traffic, not just the blocked GPS service. **D**, A policy waiver for an entire device category is a broad exception that should only be used when a targeted technical fix is not feasible; it should not be the initial response to a configurable rule issue.*

17. A CISO must implement a layered endpoint protection plan for 500 workstations under three operational constraints: (1) budget for only one EDR solution, (2) staff capacity for only two patch cycles per month, and (3) a

legacy application incompatible with the latest OS version on 40 workstations. Which implementation plan best balances security, operational constraints, and correct residual-risk logging?

○ A. Deploy EDR only on the 460 systems running the latest OS and leave the 40 legacy hosts without endpoint protection

● B. Deploy EDR on all 500 systems; apply OS patches to all systems except the 40 legacy hosts on the two monthly cycles; document the unpatched legacy systems as a risk exception with compensating controls (EDR coverage and network segmentation) recorded in a Plan of Action and Milestones (POA&M)

○ C. Apply OS patches to all 500 systems immediately, including the 40 legacy hosts, accepting that the legacy application may break in production

○ D. Postpone all EDR deployment until all 500 systems can be upgraded to the latest OS version

Correct answer: B

Why: Plan A implements EDR across all systems (including legacy hosts, which cannot be patched to the latest OS), applies patches within staff capacity for the 460 eligible systems, and correctly documents the 40 legacy hosts as a risk exception with compensating controls, per NIST SP 800-53 CA-5 (Plan of Action and Milestones) and RA-3 (Risk Assessment). This is the only option that applies available controls to all systems, operates within stated constraints, and handles residual risk through formal documentation rather than ignoring it.

*Why the others are wrong: **A**, Leaving 40 systems without any endpoint protection creates an unmanaged risk concentration, those hosts become the weakest link and a potential lateral movement staging point. **C**, Patching legacy systems with incompatible OS updates will break production applications, this violates change management principles and could cause a business continuity incident. **D**, Delaying EDR for all 500 systems while waiting for an uncertain legacy-upgrade timeline leaves the entire fleet unprotected from endpoint threats in the interim.*

18. After completing a risk assessment, a security engineer at an agricultural-tech firm implements a device hardening plan for internet-connected machinery: (1) firmware patched quarterly, (2) behavior-based anti-malware deployed, (3) host-based firewalls configured to allow only vendor update and control-platform traffic outbound, and (4) a device security policy established. Which evaluation most accurately identifies the plan's completeness gaps relative to NIST SP 800-53 implementation and logging requirements?

○ A. The plan is complete; it addresses patching, malware protection, firewall configuration, and policy, all four device-security control categories

● B. The plan is largely sound but has implementation gaps: quarterly patching is insufficient for high-severity CVEs requiring emergency response; no logging or monitoring procedure is defined for firewall events or anti-malware detections; no change-control process for firewall rule updates is specified, these gaps should be documented as residual risks in a POA&M with target remediation milestones

○ C. The plan is adequate because the physical operating environment of agricultural machinery reduces the urgency of continuous logging and monitoring

○ D. Behavior-based anti-malware makes firmware patching redundant since behavioral detection intercepts exploitation attempts before they can succeed

Correct answer: B

Why: The plan covers the core control categories but has specific implementation-quality gaps that NIST SP 800-53 would surface: (a) SI-2 (Flaw Remediation) requires risk-based patch prioritization, quarterly cadence cannot accommodate emergency patches for critical CVEs; (b) AU-2 and AU-12 (Audit Events / Audit Record Generation) require defined logging procedures for security-relevant events including firewall blocks and malware detections; (c) CM-3 (Configuration Change Control) requires a formal process for reviewing and approving firewall rule changes over time. These gaps do not invalidate the plan but must be documented as residual risks with a POA&M to be compliant with the RMF authorize step.

*Why the others are wrong: **A**, Coverage of four control categories does not equal completeness, the implementation details within each category (patch cadence, logging procedures, change control) are equally required by NIST standards. **C**, Internet-connected machinery is explicitly networked and remote-controllable; its physical operating environment does not reduce the technical threat surface or the logging requirements that apply to any connected device. **D**, Behavioral anti-malware improves detection probability but cannot reliably*

intercept all exploitation attempts, especially for vulnerabilities exploited through the device's own firmware logic before the OS or anti-malware layer is invoked.